

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 08

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM2-108)

Scenario: A credit union exercise shows that responders cannot suspend a compromised mobile-banking interface after hours because only the digital-services director has approval authority.

Which plan change would BEST resolve the weakness?

- A. Give every analyst unrestricted authority over all customer services.
- B. Require responders to wait until the digital-services director becomes available.
- C. Document risk-based suspension authority, named alternates, limits, and escalation requirements.
- D. Transfer final accountability for service suspension to the monitoring vendor.

Question 2 (CISM2-109)

Which change is MOST likely to require an immediate review of an incident response plan?

- A. A new template is adopted for weekly security reports.
- B. Incident monitoring is outsourced while the organization enters newly regulated markets.
- C. The service desk changes the order of routine ticket fields.
- D. A noncritical office printer is replaced with a similar model.

Question 3 (CISM2-110)

Scenario: A travel company's booking platform is operated by three suppliers. Their contracts require incident reporting, but the response plan does not identify who consolidates facts or authorizes coordinated action.

Which governance mechanism should the information security manager establish?

- A. A unified coordination model defining information flows, accountable owners, authority, and escalation interfaces.
- B. Independent supplier responses with no central coordination.
- C. A requirement that suppliers notify the public without consulting the company.
- D. A rule that the first supplier detecting an event becomes enterprise incident commander.

Question 4 (CISM2-111)

Scenario: A publishing group's response plan lists technical recovery steps but omits business owners, legal contacts, media coordination, supplier interfaces, and criteria for invoking continuity arrangements.

Which corrective planning action would provide the GREATEST improvement?

- A. Add more detailed instructions for collecting network packets.
- B. Ask each infrastructure specialist to create a private contact list.
- C. Limit the plan to incidents that affect the corporate data center.
- D. Create a cross-functional plan aligned with business impact, crisis, continuity, and recovery.

Question 5 (CISM2-112)

Scenario: A grocery chain identifies refrigeration monitoring as critical but omits its dependencies on cellular connectivity, time synchronization, and the external telemetry gateway.

What is the MOST significant consequence of this omission?

- A. Responders may use a different incident-ticket format.
- B. Recovery priorities may be ineffective because essential prerequisite services are not included.
- C. The refrigeration hardware may have a higher replacement cost.
- D. Every telemetry alert will automatically require disaster declaration.

Question 6 (CISM2-113)

Scenario: An arts venue's online ticket service is moderately important most weeks but becomes essential during the two hours when major-event tickets are released.

How should readiness criteria address this condition?

- A. Use time-sensitive severity and escalation criteria reflecting the peak business window.
- B. Use only the service's average annual transaction volume.
- C. Assign permanent maximum severity to every ticket-service event.
- D. Measure priority solely by the number of affected web servers.

Question 7 (CISM2-114)

Scenario: A clinical research organization has a six-hour recovery time objective for its study-management service but has not stated how much recently entered trial data may be lost.

Which requirement should be approved?

- A. A maximum number of help-desk calls during an outage.
- B. A recovery point objective based on acceptable loss of study transactions.
- C. A minimum number of analysts assigned to each alert.
- D. A fixed duration for every incident investigation.

Question 8 (CISM2-115)

Why should business continuity arrangements be coordinated with incident response?

- A. To make continuity personnel responsible for malware analysis.
- B. To ensure alternate facilities are activated for every alert.
- C. To replace containment decisions with business workarounds.
- D. To sustain prioritized activities while response and recovery address the disruption.

Question 9 (CISM2-116)

Scenario: A shipping firm plans to use a cloud collaboration site as its outage workaround. Access to that site depends on the same identity provider likely to be disabled during account-compromise containment.

Which readiness recommendation is MOST appropriate?

- A. Accept the plan because the collaboration site is hosted externally.
- B. Develop and test a workaround with independent access and communication dependencies.
- C. Increase identity logging without changing the workaround.
- D. Ban all manual business processing during incidents.

Question 10 (CISM2-117)

Scenario: A pharmacy network's manual dispensing procedure can support 15 percent of normal demand. The business impact analysis requires at least 60 percent capacity during a four-hour application outage.

Which action should be taken NEXT?

- A. Approve the procedure because any manual capacity is sufficient.
- B. Redesign and exercise the workaround to meet approved minimum capacity.
- C. Lower the business requirement without owner approval.
- D. Wait for an actual outage to determine whether demand falls.

Question 11 (CISM2-118)

Scenario: A hospitality company's recovery plan restores reservation databases before the encryption-key service needed to open those databases.

What is the BEST correction?

- A. Give both components identical recovery objectives regardless of dependency.
- B. Let whichever technician arrives first choose the restoration order.
- C. Recover the public website first because it is customer-facing.
- D. Restore the key service before dependent reservation databases.

Question 12 (CISM2-119)

Scenario: A mining company's disaster recovery exercise is declared successful when backup files are copied to the recovery site. No application starts, interfaces, or operational transactions are tested.

What should the next exercise require?

- A. Only a comparison of backup-storage costs.
- B. A longer list of files copied during the exercise.
- C. A review of employee transportation to the recovery site.
- D. End-to-end restoration and validation of prioritized services, interfaces, data, and recovery objectives.

Question 13 (CISM2-120)

Which input should MOST directly determine technology restoration priorities in a disaster recovery plan?

- A. Approved business impact, recovery objectives, and service dependencies.
- B. The order in which systems were originally purchased.
- C. The preferences of individual system administrators.
- D. The number of pages in each recovery procedure.

Question 14 (CISM2-121)

Scenario: A design firm rates incidents only by endpoint count. A compromise of one unreleased-product repository is therefore rated below nuisance software found on many kiosks.

Which modification would BEST improve severity decisions?

- A. Rate incidents solely by the cost of affected devices.
- B. Include information sensitivity, integrity, criticality, scope, urgency, and external obligations.
- C. Let each responder invent a rating based on experience.
- D. Assign maximum severity to every repository alert.

Question 15 (CISM2-122)

Scenario: A renewable-energy company directs staff to escalate incidents whenever they feel uncomfortable. Exercises show inconsistent involvement of safety, legal, and executives.

What should replace the instruction?

- A. Escalate only after permanent financial loss is proven.
- B. Escalate whenever two employees discuss the same alert.
- C. Use thresholds based on safety, business impact, information, scope, and obligations.
- D. Send every alert directly to the board.

Question 16 (CISM2-123)

Scenario: A government contractor uses ten technical incident categories, but none identifies business severity, required authority, or notification paths. Teams consistently choose the correct category yet respond inconsistently.

Which change is MOST effective?

- A. Add an impact-based severity model and map category-severity combinations to owners, actions, and escalation.
- B. Create additional categories for every device model.
- C. Replace all categories with estimated repair cost.
- D. Keep the model unchanged and ask analysts to work faster.

Question 17 (CISM2-124)

Scenario: A rail operator's technical responders perform well, but an exercise reveals no trained alternate for safety liaison and no one able to brief regulators.

Which readiness action should the information security manager take NEXT?

- A. Assign both duties permanently to the newest analyst.
- B. Remove regulatory injects from future exercises.
- C. Map competencies to roles, train designated personnel and alternates, and retest the gaps.
- D. Ask the regulator to provide the organization's incident leadership.

Question 18 (CISM2-125)

Scenario: A payment processor's annual exercise consists entirely of analysts demonstrating security-tool features to observers. Leadership later assumes the incident plan has been validated.

How should the exercise be redesigned?

- A. Measure only how many tool functions analysts can demonstrate.
- B. Exclude business and legal participants to keep the exercise technical.
- C. Use realistic injects to test authority, business decisions, communications, dependencies, and recovery coordination.
- D. Declare the plan validated because technical tools operated successfully.

Question 19 (CISM2-126)

Which method is MOST appropriate for testing executive decision making during a severe scenario without interrupting live services?

- A. An unannounced production shutdown.
- B. A facilitated tabletop exercise with escalating business and stakeholder injects.
- C. A routine vulnerability scan.
- D. A review limited to responder attendance records.

Question 20 (CISM2-127)

Scenario: A port authority's simulation report lists issues but labels them optional observations. No owner, target date, or follow-up test is assigned.

Which follow-up requirement should the information security manager impose?

- A. Prioritized corrective actions with owners, due dates, acceptance criteria, and retesting.
- B. Removal of difficult findings from the final report.
- C. A higher participant count as the only performance measure.
- D. Automatic plan approval because the simulation finished.

Question 21 (CISM2-128)

What should incident triage establish FIRST?

- A. The final root cause and all corrective actions.
- B. The wording of an external public statement.
- C. Whether the activity meets incident criteria and its initial impact and routing.
- D. The permanent replacement design for affected systems.

Question 22 (CISM2-129)

Scenario: A factory receives simultaneous reports of blocked phishing emails and inconsistent readings from a sensor used to prevent equipment overheating.

Which report should be assessed FIRST?

- A. The phishing reports because they involve more messages.
- B. The sensor-integrity report because it may indicate immediate safety and operational risk.
- C. Neither until financial loss is confirmed.
- D. Both only after the next shift begins.

Question 23 (CISM2-130)

Scenario: Temporary workers at an agricultural company do not have access to the employee service portal. They report suspicious activity informally to supervisors, and several reports never reach security.

What is the MOST appropriate action?

- A. Provide accessible, monitored reporting channels with defined intake, acknowledgment, and escalation.
- B. Ask supervisors to conduct forensic analysis first.
- C. Require temporary workers to prove an incident before reporting.
- D. Accept the missed reports because temporary workers are not employees.

Question 24 (CISM2-131)

Scenario: A smart-building controller is repeatedly unlocking restricted doors. Facilities can switch it to a safe manual mode, but doing so may overwrite some volatile diagnostic data.

Which response should the information security manager support FIRST?

- A. Leave doors uncontrolled until all volatile data is collected.
- B. Secure the doors under authorized procedures and preserve available evidence.
- C. Destroy the controller immediately without recording the action.
- D. Wait for the controller vendor to accept responsibility.

Question 25 (CISM2-132)

Scenario: A managed service provider may have caused a customer-data exposure. The provider offers to conduct the only investigation and deliver a summary without underlying evidence.

What is the BEST response?

- A. Require appropriately independent investigation, contractual evidence access, and coordinated legal oversight.
- B. Close the incident once the provider promises remediation.
- C. Accept the summary because the provider knows the environment.
- D. Publish an accusation before reviewing the evidence.

Question 26 (CISM2-133)

Scenario: During an investigation of inventory fraud, a manager emails exported access logs among several teams. No hash, source record, custodian, or transfer history is retained.

What is the PRIMARY concern?

- A. The logs will necessarily identify the wrong suspect.
- B. The warehouse recovery objective must be revised.
- C. The event must be declared a disaster.
- D. Evidence integrity and custody may not be demonstrable.

Question 27 (CISM2-134)

Scenario: A multinational employer plans to collect complete personal-device images from employees in several countries after suspected source-code leakage. Local privacy and employment restrictions may differ.

Which coordination step should the information security manager take NEXT?

- A. Collect every device immediately under one global rule.
- B. Ask line managers to decide individually what laws apply.
- C. Coordinate legal, privacy, and HR on lawful collection and preservation.
- D. Notify the suspected employee publicly before collection.

Question 28 (CISM2-135)

What is the MOST important basis for choosing an incident containment action?

- A. Ongoing harm, safety, business impact, evidence, authority, and recovery options.
- B. The preferred tool of the first responder.
- C. The action used in the most recent incident.
- D. The number of systems listed in the asset inventory.

Question 29 (CISM2-136)

Scenario: A payroll provider confirms abusive requests from one partner API credential. Disabling the entire API platform would prevent thousands of customers from submitting payroll.

Which targeted containment approach is BEST?

- A. Isolate the affected credential and connection, preserve evidence, and monitor abuse.
- B. Leave the credential active until the partner completes its investigation.
- C. Shut down all customer payroll services without impact assessment.
- D. Erase the API platform before retaining relevant records.

Question 30 (CISM2-137)

Scenario: A hospital has infusion devices that cannot receive a security update for three months. Network restrictions can reduce exposure, but they increase maintenance effort and must not interfere with clinical alarms.

Which approach is MOST appropriate?

- A. Restore normal connectivity because maintenance effort is inconvenient.
- B. Accept exposure permanently without clinical approval.
- C. Approve tested, monitored restrictions with clinical oversight and a remediation deadline.
- D. Disconnect all devices immediately without considering patient care.

Question 31 (CISM2-138)

Scenario: A news outlet reports that a sports association leaked member payment data. The team has confirmed unauthorized access to a web server but has not established whether payment records were present.

Which communications action is MOST appropriate at this stage?

- A. Confirm the reported leak to demonstrate transparency.
- B. Release investigators' competing theories.
- C. Refuse all updates until the post-incident review.
- D. Issue a factual holding statement with actions and update channels.

Question 32 (CISM2-139)

Scenario: A software provider confirms that a customer-hosted integration key was exposed. Contracts differ on reporting recipients and timing, and the investigation is still refining the affected-customer list.

What should the information security manager do FIRST?

- A. Coordinate legal, privacy, contract, and account owners to assess verified facts against applicable obligations.
- B. Apply the shortest deadline from any contract to every customer without review.
- C. Announce that every customer key was exploited.
- D. Wait for complete root-cause analysis before examining notification duties.

Question 33 (CISM2-140)

Scenario: During a payment outage, directors receive hundreds of technical alerts while engineers receive only a financial-loss estimate. Neither audience can make the decisions assigned to it.

Which reporting design would BEST resolve the problem?

- A. Send every recipient the same raw incident record.
- B. Permit each team to publish independent incident status.
- C. Tailor updates from one verified source to each audience's decisions and cadence.
- D. Stop scheduled reporting and answer only urgent messages.

Question 34 (CISM2-141)

Scenario: A cyber-related water-distribution outage expands to multiple communities, threatens service to medical facilities, and attracts intense public attention. Routine technical status calls continue.

What should happen NEXT?

- A. Wait for final root cause before involving executives.
- B. Activate the crisis structure and coordinate operational, executive, government, customer, and public communications.
- C. Allow engineers to provide individual media interviews.
- D. Close the security incident because community services own the visible impact.

Question 35 (CISM2-142)

Scenario: A manufacturer is ready to restore production systems after destructive malware, but one recent backup was connected to the affected environment and has not been examined.

What should occur before restoration from that backup?

- A. Use it immediately because it is the newest copy.
- B. Discard every backup without assessment.
- C. Restore it directly into production and observe the result.
- D. Validate clean backups in isolation and select a business-aligned recovery point.

Question 36 (CISM2-143)

Why is enhanced monitoring commonly used after an affected service is restored?

- A. To guarantee that no future incident can occur.
- B. To eliminate the need for recovery validation.
- C. To detect recurrence, missed persistence, abnormal behavior, or recovery problems during stabilization.
- D. To transfer service acceptance to the monitoring team.

Question 37 (CISM2-144)

Scenario: An invoicing platform is available after recovery, but totals do not reconcile with the approved ledger and several downstream reports remain incomplete.

What is the BEST decision?

- A. Resume normal billing because the application starts successfully.
- B. Declare success solely because the recovery time objective was reached.
- C. Let the software vendor accept the financial risk.
- D. Retain restrictions until recovery criteria are met and the owner accepts service.

Question 38 (CISM2-145)

Scenario: A customs broker can safely restore shipment clearance but not its analytics portal. The portal depends on an interface that has not completed security validation.

Which restoration approach is MOST appropriate?

- A. Reconnect all interfaces to claim complete recovery.
- B. Keep every service offline until the analytics portal is ready.
- C. Allow each developer to reconnect components independently.
- D. Restore validated clearance functions gradually and communicate residual impact.

Question 39 (CISM2-146)

Scenario: A media platform celebrates a falling incident count, but business impact per incident is rising, detection is slower, and corrective actions remain overdue.

Which conclusion is BEST supported?

- A. The program is improving because incident count is the only meaningful measure.
- B. All incident metrics should be abandoned as misleading.
- C. Use balanced impact, timeliness, recurrence, recovery, and remediation measures.
- D. The remaining corrective actions should be closed to improve the dashboard.

Question 40 (CISM2-147)

Scenario: After a mistaken cloud change exposes internal documents, a vice president wants the review limited to deciding which engineer should be punished.

How should the information security manager redirect the review?

- A. Examine process, approvals, workload, and oversight while handling accountability separately.
- B. Exclude system and process owners from the meeting.
- C. Begin with public identification of the engineer.
- D. Cancel the review because personnel are involved.

Question 41 (CISM2-148)

Scenario: A customer portal became unavailable when its domain registration lapsed. The review finds no assigned owner, renewal notices went to a departed employee, and procurement records omitted the domain.

Which finding BEST expresses the root cause?

- A. The service desk received many calls.
- B. Customers received error messages during the outage.
- C. Responders changed name-server settings during recovery.
- D. Asset lifecycle governance failed to address ownership, renewal, and monitoring.

Question 42 (CISM2-149)

Scenario: A year after an identity incident, recommended access-process changes remain in a presentation. Teams believe some work was completed, but there are no owners, dates, evidence, or exception approvals.

Which corrective-action mechanism should the information security manager establish?

- A. Automatic closure of all recommendations after one year.
- B. A tracked action register with owners, deadlines, validation, escalation, and exceptions.
- C. A verbal update from each team with no supporting evidence.
- D. A requirement that only the original responders may review progress.

Question 43 (CISM2-150)

Scenario: A payroll vendor outage reveals that the organization's plan lacks alternate contacts, manual payroll limits, evidence-access provisions, and criteria for escalating vendor failures. Service has been restored.

Which post-incident action should be taken NEXT?

- A. Archive the incident without changes because the vendor restored service.
- B. Replace every supplier regardless of criticality.
- C. Reassess supplier incident risk, revise plans, test continuity, and track remediation.
- D. Update only the technical monitoring rule that detected the outage.

Answer Key

Domain IV - Incident Management

1 C	2 B	3 A	4 D	5 B
6 A	7 B	8 D	9 B	10 B
11 D	12 D	13 A	14 B	15 C
16 A	17 C	18 C	19 B	20 A
21 C	22 B	23 A	24 B	25 A
26 D	27 C	28 A	29 A	30 C
31 D	32 A	33 C	34 B	35 D
36 C	37 D	38 D	39 C	40 A
41 D	42 B	43 C		

Detailed Explanations

Question 1 (CISM2-108)

Correct answer: C - Document risk-based suspension authority, named alternates, limits, and escalation requirements.

Readiness requires delegated authority that is broad enough for timely protection yet bounded by defined conditions and escalation. Waiting preserves the gap, unrestricted authority is excessive, and a vendor cannot assume the organization's accountability.

Question 2 (CISM2-109)

Correct answer: B - Incident monitoring is outsourced while the organization enters newly regulated markets.

Outsourcing monitoring and entering new regulatory environments can change contacts, duties, evidence access, escalation, and notification obligations. Reporting templates, ticket layout, and a routine printer replacement do not materially alter response governance.

Question 3 (CISM2-110)

Correct answer: A - A unified coordination model defining information flows, accountable owners, authority, and escalation interfaces.

A unified model preserves organizational accountability while defining how suppliers exchange facts and support decisions. Independent responses fragment the incident picture, suppliers should not make unauthorized public statements, and detection does not confer enterprise command authority.

Question 4 (CISM2-111)

Correct answer: D - Create a cross-functional plan aligned with business impact, crisis, continuity, and recovery.

The largest gap is enterprise coordination, so a governed cross-functional framework best aligns authority, impact, obligations, and supporting plans. More technical detail, private contact lists, and a data-center-only scope leave the material omissions unresolved.

Question 5 (CISM2-112)

Correct answer: B - Recovery priorities may be ineffective because essential prerequisite services are not included.

A critical service cannot be recovered reliably when its prerequisites are absent from impact analysis and sequencing. Ticket format and hardware cost do not address operability, and missing dependencies do not automatically convert each alert into a disaster.

Question 6 (CISM2-113)

Correct answer: A - Use time-sensitive severity and escalation criteria reflecting the peak business window.

Time-sensitive criteria reflect when disruption becomes intolerable and enable proportionate preparation. Annual averages conceal peak exposure, permanent maximum severity wastes resources, and server counts do not express business impact.

Question 7 (CISM2-114)

Correct answer: B - A recovery point objective based on acceptable loss of study transactions.

The recovery point objective defines acceptable data loss and complements the recovery time objective. Call volume, staffing levels, and investigation duration do not state how far data restoration may roll back.

Question 8 (CISM2-115)

Correct answer: D - To sustain prioritized activities while response and recovery address the disruption.

Continuity arrangements preserve prioritized operations during incident containment and recovery. They do not own technical analysis, activate for every alert, or replace the incident-response process.

Question 9 (CISM2-116)

Correct answer: B - Develop and test a workaround with independent access and communication dependencies.

A viable workaround should not depend on a service likely to be unavailable in the same scenario and should be tested. External hosting does not remove the identity dependency, more logging does not restore access, and banning manual processing may defeat continuity goals.

Question 10 (CISM2-117)

Correct answer: B - Redesign and exercise the workaround to meet approved minimum capacity.

The workaround must be improved and tested against the approved capacity requirement before reliance on it. Accepting inadequate capacity or changing requirements without business approval hides the gap, while waiting for a real incident exposes operations to foreseeable failure.

Question 11 (CISM2-118)

Correct answer: D - Restore the key service before dependent reservation databases.

The prerequisite key service must be available before encrypted databases can become usable. Identical objectives do not correct sequencing, visibility does not override dependency, and ad hoc technician choice bypasses approved priorities.

Question 12 (CISM2-119)

Correct answer: D - End-to-end restoration and validation of prioritized services, interfaces, data, and recovery objectives.

Copying files proves neither recoverability nor business usability. End-to-end validation demonstrates that dependencies, data, interfaces, and objectives work together; storage cost, file count, and transportation review do not validate technology recovery.

Question 13 (CISM2-120)

Correct answer: A - Approved business impact, recovery objectives, and service dependencies.

Approved impact, recovery objectives, and dependencies connect restoration order to business need. Purchase order, administrator preference, and document length do not establish business criticality or workable sequencing.

Question 14 (CISM2-121)

Correct answer: B - Include information sensitivity, integrity, criticality, scope, urgency, and external obligations.

Multidimensional criteria capture the potentially severe confidentiality and competitive impact of a single critical repository. Device cost is incomplete, undocumented discretion produces inconsistency, and automatic maximum ratings ignore verified scope and impact.

Question 15 (CISM2-122)

Correct answer: C - Use thresholds based on safety, business impact, information, scope, and obligations.

Documented impact- and obligation-based thresholds route incidents consistently and early enough for action. Proven loss is too late, employee discussion is not a meaningful criterion, and sending every alert to the board creates noise.

Question 16 (CISM2-123)

Correct answer: A - Add an impact-based severity model and map category-severity combinations to owners, actions, and escalation.

Category identifies incident type, while severity and mappings determine urgency, authority, and response. More device categories add complexity, repair cost omits broader impact, and faster work cannot compensate for missing decision guidance.

Question 17 (CISM2-124)

Correct answer: C - Map competencies to roles, train designated personnel and alternates, and retest the gaps.

Role-based competency mapping, trained alternates, and retesting directly address the readiness failure. Arbitrary assignment is unreliable, removing injects conceals the gap, and external regulators do not provide organizational incident leadership.

Question 18 (CISM2-125)

Correct answer: C - Use realistic injects to test authority, business decisions, communications, dependencies, and recovery coordination.

An objective-driven scenario should test the cross-functional decisions and interfaces the plan depends on. Tool demonstrations alone do not validate management readiness, and excluding key participants or declaring success would preserve the assurance gap.

Question 19 (CISM2-126)

Correct answer: B - A facilitated tabletop exercise with escalating business and stakeholder injects.

A facilitated tabletop tests executive judgment and coordination through an evolving scenario without production risk. A shutdown is unnecessarily disruptive, a scan tests controls, and attendance records do not demonstrate decision capability.

Question 20 (CISM2-127)

Correct answer: A - Prioritized corrective actions with owners, due dates, acceptance criteria, and retesting.

Exercise findings should become accountable, measurable improvements whose effectiveness is retested. Removing findings suppresses learning, attendance alone does not measure capability, and exercise completion is not evidence that the plan works.

Question 21 (CISM2-128)

Correct answer: C - Whether the activity meets incident criteria and its initial impact and routing.

Triage determines whether reported activity is an incident and assigns an initial priority and route. Final root cause, public statements, and permanent redesign require later analysis or separate approval.

Question 22 (CISM2-129)

Correct answer: B - The sensor-integrity report because it may indicate immediate safety and operational risk.

Potential safety and process-integrity consequences make the sensor issue the first triage priority. Message volume alone does not establish higher impact, and delaying for a shift change or proven loss could permit preventable harm.

Question 23 (CISM2-130)

Correct answer: A - Provide accessible, monitored reporting channels with defined intake, acknowledgment, and escalation.

Accessible monitored channels enable prompt reporting and consistent triage for all relevant workers. Proof requirements discourage reporting, supervisors should not perform unqualified investigations, and employment status does not remove the organization's exposure.

Question 24 (CISM2-131)

Correct answer: B - Secure the doors under authorized procedures and preserve available evidence.

Physical safety and access protection require immediate authorized stabilization, with documentation and feasible evidence preservation. Leaving doors uncontrolled is unacceptable, undocumented destruction harms the investigation, and the organization retains decision authority.

Question 25 (CISM2-132)

Correct answer: A - Require appropriately independent investigation, contractual evidence access, and coordinated legal oversight.

Possible provider involvement creates a conflict requiring independent inquiry, access to supporting evidence, and legal coordination. Expertise alone does not remove the conflict, promised remediation does not establish facts, and public accusation is premature.

Question 26 (CISM2-133)

Correct answer: D - Evidence integrity and custody may not be demonstrable.

Missing integrity and handling records weaken the evidentiary value and defensibility of the logs. This does not predetermine a suspect, define a disaster, or directly change a business recovery objective.

Question 27 (CISM2-134)

Correct answer: C - Coordinate legal, privacy, and HR on lawful collection and preservation.

Cross-border personal-device collection requires early specialist coordination to establish lawful authority, proportionality, preservation, and handling. A universal approach may violate local requirements, line managers lack suitable authority, and public identification is premature.

Question 28 (CISM2-135)

Correct answer: A - Ongoing harm, safety, business impact, evidence, authority, and recovery options.

Containment should be proportionate to the current harm and coordinated with operational, safety, evidentiary, authority, and recovery needs. Responder preference, prior use, and asset count alone do not establish the best action.

Question 29 (CISM2-136)

Correct answer: A - Isolate the affected credential and connection, preserve evidence, and monitor abuse.

Targeted isolation stops the confirmed path while limiting collateral business impact and preserving evidence. Waiting permits continued abuse, full shutdown may be disproportionate, and erasure destroys information needed for investigation and recovery.

Question 30 (CISM2-137)

Correct answer: C - Approve tested, monitored restrictions with clinical oversight and a remediation deadline.

Long-term containment should be tested for safety, approved by accountable stakeholders, monitored, time-bounded, and tied to permanent remediation. Convenience does not justify exposure, silent acceptance lacks accountability, and indiscriminate disconnection may endanger care.

Question 31 (CISM2-138)

Correct answer: D - Issue a factual holding statement with actions and update channels.

At this phase, a factual holding statement addresses stakeholder needs while protecting accuracy. Confirming an unsupported claim or publishing theories creates misinformation, while prolonged silence can amplify confusion during a visible incident.

Question 32 (CISM2-139)

Correct answer: A - Coordinate legal, privacy, contract, and account owners to assess verified facts against applicable obligations.

Notification analysis should begin promptly using verified facts and the obligations that apply to each relationship. One universal deadline may be wrong, broad claims may be unsupported, and waiting for full root cause can delay required action.

Question 33 (CISM2-140)

Correct answer: C - Tailor updates from one verified source to each audience's decisions and cadence.

A common verified source preserves consistency, while tailored content and cadence make updates actionable for each stakeholder. Raw uniform reporting creates noise, independent status creates contradictions, and purely reactive communication weakens coordination.

Question 34 (CISM2-141)

Correct answer: B - Activate the crisis structure and coordinate operational, executive, government, customer, and public communications.

The widespread essential-service impact requires enterprise crisis leadership and coordinated communications before root cause is final. Individual media responses risk inconsistency, and operational ownership does not end the underlying incident.

Question 35 (CISM2-142)

Correct answer: D - Validate clean backups in isolation and select a business-aligned recovery point.

Recovery should use a validated clean source and an appropriate recovery point to avoid reintroducing the incident or corrupted data. Recency alone is insufficient, discarding all backups is disproportionate, and testing directly in production creates avoidable risk.

Question 36 (CISM2-143)

Correct answer: C - To detect recurrence, missed persistence, abnormal behavior, or recovery problems during stabilization.

Enhanced monitoring provides added assurance during stabilization by detecting recurrence or overlooked issues. It supplements rather than replaces validation, cannot guarantee zero future incidents, and does not transfer business acceptance authority.

Question 37 (CISM2-144)

Correct answer: D - Retain restrictions until recovery criteria are met and the owner accepts service.

Availability alone does not prove trustworthy recovery. Controlled restrictions should remain until integrity, interfaces, and business acceptance criteria are satisfied; a vendor cannot own the business decision, and meeting a time target does not excuse failed validation.

Question 38 (CISM2-145)

Correct answer: D - Restore validated clearance functions gradually and communicate residual impact.

Staged restoration delivers the prioritized validated service while containing risk from an unvalidated dependency. Full reconnection sacrifices assurance, holding all services is unnecessarily disruptive, and independent reconnection bypasses recovery governance.

Question 39 (CISM2-146)

Correct answer: C - Use balanced impact, timeliness, recurrence, recovery, and remediation measures.

A single volume metric hides worsening impact, slower detection, and remediation delay. Balanced measures support sound post-incident evaluation, while abandoning metrics or closing incomplete actions would conceal rather than manage risk.

Question 40 (CISM2-147)

Correct answer: A - Examine process, approvals, workload, and oversight while handling accountability separately.

A post-incident review should identify systemic conditions and sustainable improvements, with personnel matters handled separately through appropriate processes. Canceling, excluding owners, or publicly blaming an individual undermines learning and candor.

Question 41 (CISM2-148)

Correct answer: D - Asset lifecycle governance failed to address ownership, renewal, and monitoring.

The governance and lifecycle failure explains why a predictable renewal need caused the incident. Error messages and calls are symptoms, while name-server changes were recovery actions rather than the underlying cause.

Question 42 (CISM2-149)

Correct answer: B - A tracked action register with owners, deadlines, validation, escalation, and exceptions.

A governed register makes remediation accountable, measurable, verifiable, and subject to explicit residual-risk decisions. Elapsed time, unsupported verbal claims, and limiting oversight to responders do not demonstrate effective completion.

Question 43 (CISM2-150)

Correct answer: C - Reassess supplier incident risk, revise plans, test continuity, and track remediation.

The post-incident phase should address the full set of dependency, contract, continuity, escalation, and assurance gaps and verify improvements. Restoration alone does not resolve them, replacing all suppliers is disproportionate, and a monitoring-only change is incomplete.